System Testing Report (Mini-Project Part-3 §2.b.ii)

Also referred to as the System Validation Report.

> **Course:** Software Engineering | **Section:** A | **Team Number:** 9
> **Target System:** Online Exam Portal (OEP)
> **Testing Window:** 2 – 6 November 2026 (Sprint 3); results regenerated 12 November 2026 after the v1.0.1 fixes
> **Team:** Aadish Sarin (`PES2UG24CS007` , QA Lead) · A S Vincent (`PES2UG24CS002` , Dev Lead) · Aditya Rao (`PES2UG24CS034` , DevOps Lead) · Akshansh Agrawal (`PES2UG24CS045` , Performance Lead)
> **Code tested:** commit `57e01fd` on `main` · **Repository:** https://github.com/vinnieee7/SE-Online-Exam-Portal-Team09

1. Summary

System testing checks the integrated application — React frontend, Express API, SQLite database and middleware — against the SRS requirements, as planned in STP §5.

Test type	Tool	Scope	Result
API system tests	Jest + Supertest	Real HTTP requests through every module, 51 cases	**51/51 pass**
Browser test `TC-Take-06`	Built-in browser, React dev mode	Exam timer and auto-submit at 00:00	**Pass** (after DEF-007 / DEF-008 fixes)
End-to-end scenarios	Supertest + browser	4 user journeys across roles	**4/4 pass**
Performance `TC-Perf-01/02`	Apache JMeter 5.6.3	500 candidates for 10 minutes	p90 **41 ms**, 0 errors in 148,980 auto-saves; NF-002 **Partial**
Vulnerability scan	OWASP ZAP 2.17.0	All 26 API routes, passive + active	No confirmed vulnerability after fixes; remaining alerts analysed as false positives or accepted risk
Accessibility `TC-UX-01`	Lighthouse 12.8.2 + axe-core 4.10.2	Every page and dialog, WCAG 2.1 A/AA	**0 violations**; login 100/100

Exit criteria (STP §5.4): met. 0 open Critical or High defects; 25 of 26 requirements Accepted, OEP-NF-002 Partial (explained in §5).

2. Test environment

Component	Version / setting
Backend	Node.js, Express 5, JWT (jsonwebtoken), bcryptjs
Database	SQLite 3 in WAL mode, foreign keys on; reset to the same seed data before every test file (STP §6.4)

Component	Version / setting
Frontend	React 19 + Vite 8
Test tools	Jest 30.5.2, Supertest 7, Apache JMeter 5.6.3, OWASP ZAP 2.17.0, Lighthouse 12.8.2, axe-core 4.10.2
CI	GitHub Actions (`.github/workflows/ci.yml`): on every push and pull request, installs, reseeds the database, runs all tests and builds the frontend
Seed accounts	`admin@pesu.edu` , `instructor1@pesu.edu` , `student1@pesu.edu` , `student2@pesu.edu` , `locked@pesu.edu`

3. API system test results

Command: `cd backend && npm test` — run 12 November 2026, commit `57e01fd` .

Module workflows (all four modules) — `api.test.js` (19/19 pass, 0.57 s)

Test	Requirement	Result
TC-SYS-01: Health check returns online status	—	**PASS**
TC-Auth-01: Register a new student account successfully	OEP-F-001..004	**PASS**
TC-Auth-01a: Duplicate email registration is rejected with 409 Conflict	OEP-F-001..004	**PASS**
TC-Auth-02: Valid credentials login returns JWT session with role claims	OEP-F-001..004	**PASS**
TC-Auth-02a: Invalid password returns 401 Unauthorized	OEP-F-001..004	**PASS**
TC-Auth-02b: Locked account login is blocked with 403 Forbidden	OEP-F-001..004	**PASS**
TC-Auth-03: Password reset OTP request returns verification code	OEP-F-001..004	**PASS**
TC-Auth-04: RBAC enforces that Students cannot create exams (403 Forbidden)	OEP-F-001..004	**PASS**
TC-Exam-01: Instructor creates a new scheduled exam	OEP-F-005..008	**PASS**
TC-Exam-03: Exam scheduling blocks start time after end time (400 Bad Request)	OEP-F-005..008	**PASS**
TC-Exam-02: Instructor adds question with options to question bank	OEP-F-005..008	**PASS**
TC-Take-01 & TC-Sec-05: Student starts active exam (correct_answer stripped from payload)	OEP-F-009..012, OEP-SR-004	**PASS**
TC-Take-03: Periodic auto-save persists student answers	OEP-F-009..012, OEP-SR-004	**PASS**
TC-Take-04: Student submits exam attempt and triggers auto-grading	OEP-F-009..012, OEP-SR-004	**PASS**
TC-Eval-01: Auto-grading correctly computed score for objective questions	OEP-F-013..016, OEP-SR-005	**PASS**
TC-Eval-03 & TC-Sec-06: Student result privacy strictly blocks cross-student access (403 Forbidden)	OEP-F-013..016, OEP-SR-005	**PASS**
TC-Eval-02: Instructor grades subjective question manually	OEP-F-013..016, OEP-SR-005	**PASS**
TC-Eval-04: Instructor retrieves aggregate class analytics and item analysis	OEP-F-013..016, OEP-SR-005	**PASS**
TC-Sec-04: Administrator retrieves persistent audit logs	OEP-NF-004	**PASS**

Security requirements — `security.test.js` (19/19 pass, 1.13 s)

Test	Requirement	Result
TC-Sec-01a: the API answers over HTTPS	OEP-SR-001	**PASS**
TC-Sec-01b: a current client negotiates TLS 1.3	OEP-SR-001	**PASS**
TC-Sec-01c: a client limited to TLS 1.2 is still accepted	OEP-SR-001	**PASS**
TC-Sec-01d (control): the test client really can speak TLS 1.1	OEP-SR-001	**PASS**
TC-Sec-01e: the OEP server refuses that TLS 1.1 client	OEP-SR-001	**PASS**
TC-Sec-02a: stored passwords are bcrypt hashes with cost factor 10	OEP-SR-002	**PASS**
TC-Sec-02b: registration salts each hash and never returns it	OEP-SR-002	**PASS**
TC-Sec-03a: a request without a token gets 401	OEP-SR-003	**PASS**
TC-Sec-03b: a token whose payload was edited to role Admin is rejected	OEP-SR-003	**PASS**
TC-Sec-03c: a token signed with a different secret is rejected	OEP-SR-003	**PASS**
TC-Sec-03d: an unsigned token (alg "none") is rejected	OEP-SR-003	**PASS**
TC-Sec-03e: a valid Student token cannot reach Instructor or Admin APIs	OEP-SR-003	**PASS**
TC-Sec-03g: self-registration cannot create an Administrator account	OEP-SR-003	**PASS**
TC-Sec-03f: locking an account blocks a token that was issued before the lock	OEP-SR-003	**PASS**
TC-Sec-07a: classic SQL login-bypass strings do not log anyone in	—	**PASS**
TC-Sec-07b: a DROP TABLE payload is stored as text and the users table survives	—	**PASS**
TC-Sec-07c: an injection payload in a URL id does not widen the query	—	**PASS**
TC-Sec-07e: malformed or missing bodies get 400 with no internal details (ZAP finding)	—	**PASS**
TC-Sec-07d: script markup in a question is returned as JSON data, not executed by the API	—	**PASS**

Requirement verification (timer, shuffle, concurrency) — `verification.test.js` (13/13 pass, 0.46 s)

Test	Requirement	Result
TC-Exam-04a: a shuffle keeps every item exactly once and leaves the input untouched	OEP-F-008	**PASS**
TC-Exam-04b: all 24 orders of 4 questions are equally likely over 24,000 shuffles	OEP-F-008	**PASS**
TC-Exam-04c: a candidate gets every linked question exactly once, without answer keys	OEP-F-008	**PASS**
TC-Exam-01b: linking a question id that does not exist returns 400, not 500	OEP-F-005	**PASS**
TC-Take-02a: a new attempt gets the full 45-minute duration (2700 s)	OEP-F-010, DEF-002	**PASS**
TC-Take-02b: the clock keeps running on the server (40 min elapsed leaves about 300 s)	OEP-F-010, DEF-002	**PASS**
TC-Take-02c: remaining time is capped by the exam window end	OEP-F-010, DEF-002	**PASS**
TC-Take-02d: an attempt past its duration reports 0 seconds left	OEP-F-010, DEF-002	**PASS**

Test	Requirement	Result
TC-Take-02e (DEF-002 regression): a SQLite UTC timestamp without "Z" is read as UTC, even on an IST server	OEP-F-010, DEF-002	**PASS**
TC-Auth-03b: requesting a new code invalidates the previous unused one	OEP-F-003	**PASS**
TC-Take-05a: two simultaneous start requests share one attempt and one audit entry	DEF-009, DEF-010	**PASS**
TC-Take-05b: resuming an attempt returns the questions in the same order	DEF-009, DEF-010	**PASS**
TC-Take-05c: two candidates get different question orders	DEF-009, DEF-010	**PASS**

4. End-to-end scenarios

4.1 Candidate takes an exam (M1 → M3 → M4)

1. `student1` logs in (`POST /api/auth/login`) and receives a JWT.
2. Lists exams (`GET /api/exams`) — only published exams are shown.
3. Starts the exam (`GET /api/delivery/exams/1/attempt`): questions arrive in a per-attempt shuffled order with no answer keys (DEF-001), and the remaining time comes from the server (DEF-002).
4. Answers are auto-saved (`POST /api/delivery/attempts/:id/answers`) and the exam is submitted (`POST /api/delivery/attempts/:id/submit`); objective questions are graded at once.

Pass — `TC-Auth-02`, `TC-Take-01`, `TC-Sec-05`, `TC-Take-03`, `TC-Take-04`, `TC-Eval-01`, `TC-Take-05b`.

4.2 Instructor authors, grades and reviews (M2 → M4)

1. `instructor1` creates an exam (`POST /api/exams`); an end time before the start time is rejected with 400 (DEF-004).
2. Adds questions to the bank (`POST /api/exams/questions`).
3. Opens submissions (`GET /api/eval/exams/1/submissions`), grades a short answer (`POST /api/eval/attempts/:id/grade`) and views analytics (`GET /api/eval/exams/1/analytics`).

Pass — `TC-Exam-01`, `TC-Exam-02`, `TC-Exam-03`, `TC-Eval-02`, `TC-Eval-04`.

4.3 Administrator audit and account lock

1. `admin` reads the audit trail (`GET /api/audit-logs`).
2. A locked account cannot log in (403), and a token issued before the lock stops working at once.

Pass — `TC-Sec-04`, `TC-Auth-02b`, `TC-Sec-03f`.

4.4 One candidate cannot see another's result

`student2` requests `student1`'s scorecard (`GET /api/eval/attempts/:id/scorecard`) and gets 403 (DEF-005).

Pass — `TC-Eval-03`, `TC-Sec-06`.

4.5 Browser test `TC-Take-06`: timer and auto-submit

Step	Before the fix	After the fix
Compare the exam timer with a clock	10 timer seconds passed in 5 real seconds (DEF-008)	10 timer seconds in 10.0 s
Let a 15-second exam reach 00:00	Submit sent to `/attempts/null/submit` → 404; screen froze (DEF-007)	One submit → 200; "Time is up"; attempt graded

5. Non-functional requirements

Requirement	Target	Measured	Status
OEP-NF-001 Response time	p90 ≤ 3.0 s	p90 41 ms for auto-save, 48 ms over all 149,980 requests (JMeter, 11 Nov 2026)	**Met**
OEP-NF-002 500 concurrent students	No degradation	500 candidates for 10 min: 0 errors, ~235 requests/s. When all 500 open a new connection in the same instant, the Windows test laptop refused 16–25% before they reached the API	**Partial**
OEP-NF-003 Answer recovery	Saved answers survive refresh	Auto-save persists answers; resuming returns them in the same order	**Met** (`TC-Take-03`, `TC-Take-05b`)
OEP-NF-004 Audit logging	Privileged actions logged	`audit_logs` table, visible to Admin	**Met** (`TC-Sec-04`, `TC-Take-05a`)
OEP-NF-005 Accessibility	WCAG 2.1 AA	0 axe violations on every page and dialog; Lighthouse 100/100 on login	**Met**

Full results: `docs/deliverable-4/evidence/` (performance-load-test.md, security-scan.md, accessibility-audit.md).

6. Defects

12 defects were logged and all 12 are closed, each with a regression test (`docs/deliverable-4/defect-log.md`).

Severity	Defects	Open
Critical	DEF-001 answer-key leak, DEF-005 scorecard IDOR, DEF-007 auto-submit failure	0
High	DEF-002 timer time zone, DEF-004 end before start, DEF-008 double-speed timer, DEF-011 slow writes under load	0
Medium	DEF-003 email case, DEF-006 logger crash, DEF-009 duplicate start, DEF-010 order changed on refresh, DEF-012 internal errors leaked	0

DEF-001 – DEF-006 were found by cross-testing during the sprints; DEF-007 – DEF-012 by the browser test, the load test and the ZAP scan.

7. Known gaps

- Updating or deleting an exam, deleting a question and locking/unlocking a user from the Admin screen work in the browser but have no automated test yet (see the Code Coverage Report).
- OEP-NF-002 is Partial because of the connection burst on the Windows test host; a Linux server with a larger connection backlog is expected to remove it, but that was not tested.

Prepared by Aadish Sarin (QA Lead).